

README: KIT INTEGRAL DE ENCUESTA DE CIBERSEGURIDAD MERCURY

Bienvenida, Instrucciones de Uso y Soporte

CONTENIDO DEL KIT

Este kit contiene **7 documentos profesionales** para evaluar integralmente la madurez de ciberseguridad de tu organización:

1 ENCUESTA INTEGRAL (01-Encuesta-Integral.md)

- 112 preguntas estructuradas en 12 dominios
- Formato: Escala Likert 1-5
- Tiempo: 90-120 minutos (completo) o modular
- Público: CISO, Directores técnicos, Compliance
- Uso: Administrar a responsables de seguridad

2 GUÍA METODOLÓGICA (02-Guia-Metodologica.md)

- Explicación detallada de cálculos
- Fórmulas para IGM, NIST CSF, ROICS
- Interpretación de resultados
- Benchmarks internacionales
- Uso: Referencia técnica para analistas

3 NARRATIVA EXPLICATIVA (03-Narrativa-Explicativa.md)

- Tono irónico-literario (como solicitaste)
- Explicación de por qué estos números importan
- Contexto histórico de ciberseguridad España
- Uso: Lectura motivadora para equipos

4 MAPEO NORMATIVO (04-Mapeo-Normativo.md)

- Vinculación pregunta → requisito normativo
- Tablas: NIS2, ISO 27001, NIST CSF
- Sanciones regulatorias (contexto)
- Cronograma transposición NIS2 España
- Uso: Demostración de conformidad regulatoria

5 PLANTILLA EXCEL (05-Plantilla-Excel.md)

- Especificaciones para hoja de cálculo
- Fórmulas IGM, PD, NIM, ICN, ROICS
- Cálculo automatizado de métricas
- Dashboard visual (gráficos)
- Uso: Implementar en Excel/Google Sheets

6 REPORTE EJECUTIVO PowerPoint (06-Reporte-Ejecutivo.md)

- 20 diapositivas profesionales
- Estructura lista para Junta Directiva
- Gráficos, tablas, recomendaciones
- Notas del orador incluidas
- Uso: Presentar resultados ejecutivos

7 Este README (07-README.md)

- Instrucciones de uso integral
- Roadmap implementación
- Soporte y contacto
- FAQs

GUÍA DE USO RÁPIDO (5 PASOS)

Paso 1: Preparación (1-2 días)

1. Descargar los 7 documentos
2. Nombrar "Responsable de Proyecto" (típicamente CISO)
3. Seleccionar respondientes:
 - Equipo de seguridad: 3-5 personas
 - Auditor interno: 1 persona
 - Directores de áreas clave: 2-3 personasTOTAL: 6-9 personas (idealmente)
4. Explicar propósito (mejora, no culpa)
5. Agendar tiempo dedicado (2-4 horas por persona)

Paso 2: Administración de Encuesta (1 semana)

1. Distribuir 01-Encuesta-Integral.md
2. Indicaciones:
 - Responder honestamente (no optimista)
 - Si desconoce → marcar "Desconoce"
 - Tiempo estimado: 90-120 minutos
3. Recolectar respuestas (formulario o email)
4. Crear hoja Excel consolidada (plantilla 05)
5. Revisar completitud y consistencia

Paso 3: Cálculos (2-3 días)

1. Abrir 05-Plantilla-Excel.md
2. Implementar en Excel con fórmulas
3. Alimentar respuestas de encuesta
4. Ejecutar cálculos automáticos:
 - IGM (Índice Global de Madurez)
 - PD (Puntuación por Dominio)
 - NIM (Nivel NIST CSF)
 - ICN (Conformidad Normativa)
 - ROICS (Retorno sobre Inversión)
5. Generar dashboard visual

Paso 4: Análisis y Reporte (3-5 días)

1. Consultar 02-Guia-Metodologica.md para interpretación
2. Revisar 04-Mapeo-Normativo.md para contexto legal
3. Identificar:
 - Top 3 dominios con brecha crítica
 - Impacto regulatorio (NIS2, ISO 27001)
 - Oportunidades de ROI
4. Redactar hallazgos principales
5. Estructurar recomendaciones

Paso 5: Presentación Ejecutiva (1 semana)

1. Adaptar 06-Reporte-Ejecutivo.md a tu contexto
2. Crear presentación PowerPoint con:
 - Resultados globales (IGM, ICN, ROICS)
 - Gráficos de dominios
 - Top 5 recomendaciones
 - Roadmap 12 meses
 - Análisis financiero
3. Leer 03-Narrativa-Explicativa.md para tono
4. Presentar a Junta Directiva
5. Solicitar aprobación de presupuesto/plan



CRONOGRAMA COMPLETO (4-5 SEMANAS)

SEMANA 1: PREPARACIÓN Y LANZAMIENTO

- Lunes: Briefing con CISO y stakeholders
- Martes-Miércoles: Selección de respondientes + envío
- Jueves-Viernes: Kick-off sesiones, Q&A
- Entregable: 100% encuestas administradas

SEMANA 2: RECOLECCIÓN DE DATOS

- Lunes-Miércoles: Consolidación de respuestas
- Jueves: Validación de datos (rangos, completitud)
- Viernes: Backup y seguridad de datos
- Entregable: Base de datos limpia (RAW_SURVEY_DATA)

SEMANA 3: ANÁLISIS Y CÁLCULOS

- Lunes-Martes: Implementación de fórmulas Excel
- Miércoles: Generación de KPIs (IGM, ROICS, etc.)
- Jueves: Dashboard visual y gráficos
- Viernes: Validación de números
- Entregable: Excel con resultados finales

SEMANA 4: REPORTE Y RECOMENDACIONES

- Lunes-Martes: Redacción de hallazgos
- Miércoles: Mapeo normativo y riesgos
- Jueves: Priorización de recomendaciones
- Viernes: Borrador de roadmap
- Entregable: Documento análisis (Word/PDF)

SEMANA 5: PRESENTACIÓN EJECUTIVA

- Lunes-Martes: Creación de PowerPoint
- Miércoles: Ensayo y validación
- Jueves: Presentación a Junta Directiva
- Viernes: Q&A, aprobación de plan
- Entregable: Aprobación + presupuesto asignado

ROLES Y RESPONSABILIDADES

Rol	Documento Clave	Tiempo	Responsabilidad
CISO / Director Seguridad	Todos (propietario)	40 horas	Orquestación, decisiones, recomendaciones
Analista SIEM	01 (SIEM), 02 (detección)	8 horas	Input técnico en dominio SIEM
Responsable Vulnerabilidades	01 (VUL), 02 (métricas)	4 horas	Datos de escaneo, MTTR
Jefe de Capacitación	01 (CAP), 02 (métricas)	4 horas	Datos de programas de training
Oficial Cumplimiento	01 (NORM), 04 (mapeo)	8 horas	Requisitos NIS2, ISO 27001
CTO / Director Técnico	01 (CTRL), 06 (reporte)	12 horas	Input de controles técnicos
CFO / Director Financiero	05 (Excel), 06 (ROI)	6 horas	Validación de beneficios financieros
Equipo de Análisis	02, 04, 05, 06	20 horas	Cálculos, interpretación, presentación
Auditor Interno	01, 04	4 horas	Validación de respuestas

CÓMO INTERPRETAR TUS RESULTADOS

Índice Global de Madurez (IGM: 0-5)

IGM < 1.5	→ TIER 1 - EMERGENTE Riesgo: Crítico. Acción inmediata. Tiempo mejora: 24 meses
IGM 1.5-2.5	→ TIER 2 - BÁSICO Riesgo: Alto. Plan de mejora requerido. Tiempo mejora: 18-24 meses
IGM 2.5-3.5	→ TIER 3 - ESTABLECIDO (TÚ ERES AQUÍ) Riesgo: Moderado-alto. Optimización necesaria. Tiempo mejora: 12-18 meses
IGM 3.5-4.5	→ TIER 4 - GESTIONADO Riesgo: Moderado. Mejora continua. Tiempo mejora: 12+ meses
IGM > 4.5	→ TIER 5 - OPTIMIZADO Riesgo: Bajo. Liderazgo del sector. Tiempo mejora: Investigación y innovación

Conformidad Normativa (ICN: %)

ICN $\geq$ 80%	→ CONFORME Cumplimiento de NIS2 e ISO 27001 logrado
ICN 60-79%	→ PARCIALMENTE CONFORME Acción requerida antes de auditoría
ICN < 60%	→ NO CONFORME Riesgo regulatorio crítico Multas potenciales si se audita

Retorno sobre Inversión (ROICS: %)

ROICS > 100%	→ EXCELENTE Cada euro invertido genera >€1 en beneficio
ROICS 50-100%	→ MUY BUENO Inversión justificable fiscalmente
ROICS 25-50%	→ BUENO Beneficio regulatorio + financiero
ROICS < 25%	→ REVISAR Requiere redefinición de beneficios

ERRORES COMUNES (Y CÓMO EVITARLOS)

Error 1: Optimismo en Respuestas

Problema: CISO contesta "5/5" porque quiere impresionar.

Solución: Validar respuestas con documentación (ver políticas, pruebas).

Corrección: -0.2 a -0.3 puntos típicos (sesgo documentado).

Error 2: Preguntas Ambiguas

Problema: "¿Tenemos SIEM?" – ¿Significa SIEM completo o agregador logs?

Solución: Aclarar en formulario = "SIEM de nivel empresarial (ej: Splunk)"

Corrección: Usar definiciones en documento 01.

Error 3: No Ponderar Dominios

Problema: Todos los dominios pesan igual (peso = 8.33%)

Solución: Ajustar pesos por relevancia sector:

- Finanzas: Aumentar SIEM, NORM
- Sanidad: Aumentar CONT, CAP
- Manufactura: Aumentar SUPL, CTRL

Error 4: Ignorar Brecha vs Criticidad

Problema: "La brecha de SUPL es 2.0, pero es lo primero a fijar"

Solución: Usar matriz Brecha × Criticidad (ver documento 02)

Corrección: Priorizar por criticidad regulatoria primero.

Error 5: No Comunicar Honestidad

Problema: Equipo piensa que "esta evaluación es para culparles"

Solución: Comunicar que es para MEJORA, no para blame

Corrección: Leer documento 03 (Narrativa) a equipo.

CONFIDENCIALIDAD Y SEGURIDAD

Datos Sensibles

Este reporte contiene:

- Evaluación interna de riesgos (clasificado)
- Información de vulnerabilidades
- Datos de deficiencias de controles

Manejo Recomendado

- ✓ Almacenar en servidor seguro (encriptado)
- ✓ Acceso restringido a Junta + CISO + CFO
- ✓ No circular en email sin cifrado
- ✓ Destruir borradores después de finalización
- ✓ Auditar accesos a documento

Comunicación Pública

- ✓ Permitido: "Hemos alcanzado madurez TIER 3"
- ✓ Permitido: "Cumpliendo con NIS2"
- ✗ Prohibido: Números específicos de brechas
- ✗ Prohibido: Vulnerabilidades desagregadas

PREGUNTAS FRECUENTES (FAQs)

P: ¿Cuánto cuesta esta evaluación?

R: El kit es gratuito. Costo es tiempo interno (80 horas team) + posibles servicios profesionales (€5-15K si usas consultor externo).

P: ¿Puedo hacer la encuesta anónima?

R: No recomendado. Mejora: Respuestas honestas + aprendizaje de equipo. Si requieres anonimato, usa mediador tercero.

P: ¿Qué pasa si no tengo SIEM?

R: Responde "No existe SIEM" = 1/5. El reporte lo priorizará como acción crítica. No es juicio moral, es brújula.

P: ¿Cuál es la puntuación "buena"?

R: IGM 3.5+ es sólida. Objetivo realista en 18 meses es IGM 4.0 (Tier 4 - Gestionado).

P: ¿Debo certificarme ISO 27001?

R: No obligatorio pero recomendado si:

- Sector financiero/sanidad

- Clientes lo requieren en contratos
- Objetivo: Posicionamiento de mercado

P: ¿Cómo hago si mi IGM es bajo (< 2.0)?

R: No es vergüenza, es diagnóstico. Plan:

1. Nombrar CISO dedicado
2. Documentar políticas básicas
3. Implementar herramientas SIEM/escaneo
4. Re-evaluar en 12 meses

P: ¿Qué sucede si tengo brecha crítica y sin presupuesto?

R: Opciones:

1. Faseado: Críticas primero (€100K) vs todo (€480K)
2. Servicios gestionados (MSSP): Reduce costo operacional
3. Justificar con ROICS: ROI positivo permite préstamo/inversión

P: ¿Cuándo re-evaluar (volver a hacer la encuesta)?

R: Recomendado:

- Trimestral: Dominios críticos (GR, SIEM, NORM)
- Anual: Evaluación completa
- Post-incidente: Validar efectividad de controles



SOPORTE Y CONTACTO

Si Necesitas Ayuda:

Para interpretación técnica:

- Consultar documento 02 (Guía Metodológica)
- Revisar tablas benchmarks por sector

Para cuestiones normativas:

- Consultar documento 04 (Mapeo Normativo)
- Referencia: CNCS.es, AEPD.es, INCIBE.es

Para presentación ejecutiva:

- Usar documento 06 (PowerPoint template)
- Leer documento 03 (Narrativa) para contexto

Para cálculos de Excel:

- Documento 05 explica todas las fórmulas
- Google Sheets también funciona (cambiar referencias)

Recursos Externos Recomendados:

Recurso	Propósito	URL
INCIBE	Inteligencia de amenazas España	incibe.es
CCN-CERT	Alertas gubernamentales ciberseguridad	ccn-cert.cni.es
AEPD	Regulación GDPR/datos personales	aepd.es
CNCS	Centro Nacional Ciberseguridad	digital.gob.es/CNCS
ENISA	Guidance NIS2 EU	enisa.europa.eu
NIST	Frameworks ciberseguridad	nist.gov
Mercury	Plataforma AVRQ	mercuryrisk.com

CHECKLIST DE IMPLEMENTACIÓN

FASE 1: PREPARACIÓN

- ☐ Descargar todos los 7 documentos
- ☐ Nombrar Responsable de Proyecto (CISO)
- ☐ Seleccionar 6-9 respondientes
- ☐ Agendar sesiones de briefing
- ☐ Crear lista de distribución/drive compartido

FASE 2: ENCUESTA

- ☐ Distribuir documento 01
- ☐ Establecer fecha límite (7-10 días)
- ☐ Hacer seguimiento a respondientes
- ☐ Validar completitud de respuestas
- ☐ Consolidar en Excel

FASE 3: ANÁLISIS

- ☐ Implementar fórmulas (documento 05)
- ☐ Calcular IGM, NIST CSF, ICN, ROICS
- ☐ Generar gráficos y dashboard
- ☐ Revisar benchmark sector (documento 02)
- ☐ Identificar 3 dominios críticos

FASE 4: REPORTE

- ☐ Redactar hallazgos principales
- ☐ Mapear brechas a NIS2/ISO 27001 (documento 04)
- ☐ Priorizar recomendaciones
- ☐ Calcular roadmap 12 meses
- ☐ Revisar narrativa para contexto (documento 03)

FASE 5: PRESENTACIÓN

- ☐ Crear PowerPoint (documento 06)
- ☐ Incluir gráficos y tablas
- ☐ Preparar notas del orador
- ☐ Ensayo con equipo clave
- ☐ Presentar a Junta Directiva

FASE 6: ACCIÓN

- ☐ Obtener aprobación de presupuesto
- ☐ Asignar propietarios a recomendaciones
- ☐ Crear plan detallado (roadmap)
- ☐ Iniciar hito Q1 (crítico)
- ☐ Agendar re-evaluación (marzo 2026)

MEJORES PRÁCTICAS

Comunicación

- Honestidad es fuerza, no debilidad
- Contexto: "Estamos entre peers, mejorando juntos"
- Celebrar fortalezas mientras se abordan gaps

Participación

- Incluir diferentes áreas (no solo TI)
- Tiempo dedicado (2-4 horas por persona)
- Sin multitarea durante respuesta

Seguimiento

- Reportería trimestral de progreso
- Vincular bonificaciones a mejora de IGM
- Celebrar hitos logrados

Inversión

- Justificar con ROICS (números hablan)
- Faseado: Críticas primero, luego mejora
- ROI positivo en 18 meses típicamente

LICENCIA Y ATRIBUCIÓN

Este kit fue diseñado por un **Consorcio de Científicos de Datos y Estrategas de Ciberseguridad** especializado en evaluaciones integrales.

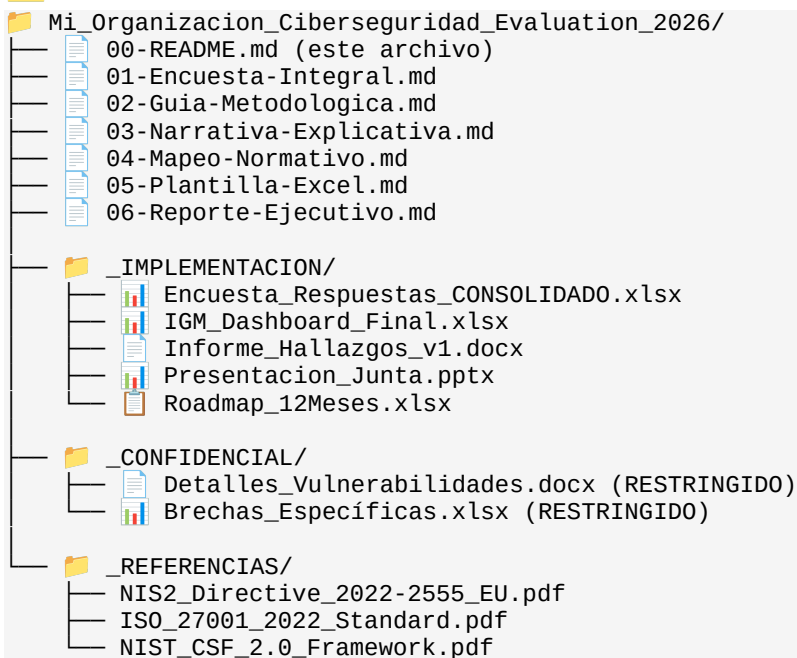
Uso:

- ✓ Libre para uso interno (organizaciones)
- ✓ Libre para referencia educativa
- ✗ No para reventa o redistribución sin atribución
- ✗ No para modificación sin consentimiento

Atribución requerida:

"Basado en Kit de Encuesta Mercury - Evaluación Integral de Ciberseguridad, Enero 2026"

ESTRUCTURA DE ARCHIVOS RECOMENDADA



PRÓXIMOS PASOS (AHORA)

Acción inmediata:

1. Lee este README (5 min)
2. Lee documento 03 Narrativa (15 min) - entiende propósito
3. Revisa documento 01 Encuesta (10 min) - ve preguntas
4. Envía documento 01 a respondientes + cronograma

Acción próxima semana:

- Consolidar respuestas
- Implementar Excel (documento 05)
- Validar números

Acción próximas 2 semanas:

- Generar reporte
- Presentar a ejecutivos
- Obtener aprobación

NOTAS FINALES

Este kit está diseñado para ser:

- **Honesto:** Sin sesgos corporativos, evaluación objetiva
- **Útil:** Orientado a acción, no solo informes
- **Ameno:** Narrativa con humor e ironía literaria
- **Profesional:** Basado en frameworks internacionales

Recuerda: Ciberseguridad es viaje, no destino. Este diagnóstico es tu brújula.

¿Preguntas? Revisa FAQs arriba, consulta documentos referenciados, o contacta a tu Responsable de Proyecto.

¡Que tengas una evaluación exitosa y una ciberseguridad más sólida en 2026!

Kit Mercury | Enero 2026 | Ponferrada, España

"Porque lo invisible merece ser medido, y lo medido puede mejorarse."